BSI Onboarding — Annex27 als Associate Resource (Supplier)

> **Status (augustus 2026):** Blok 1-3 AFGEROND — contract + NL Schedule getekend, GF077 en Supplier Data Collection ingediend, IRCA/kwalificaties + certificaten + audit-ervaring aangetoond. Resterend en actief: **§4 verzekering, §5 IT & encryptie, §6 doorlopend, en de operationele scheiding BSI-werk vs Annex27-platform.**

Rollen in de contracten

- **Supplier** = Annex27 (KBO/BCE 1006.203.170, Joseph Smeetslaan 1 bus 13630, 3630 Maasmechelen, BE) — dit ben jij als onderneming.
- **Contractor** = Raoul Haas — de persoon die de audits uitvoert.
- **Requestor** = BSI Group the Netherlands B.V. (Amsterdam, KvK 33264284). NL-recht is van toepassing.
- **Services** = ISO-audits als auditor. Start als trainee, daarna als auditor.
- **Werkvorm** = per SOW (Statement of Work) per opdracht; geen minimumafname, je mag SOW's weigeren, je mag ook voor andere klanten werken (mits gemeld en geen conflict).

Tarieven (uit SOW / Schedule 1) — ter controle

- QHSE-audits (9k, 14k, 45k, 50k): **€750/dag**
- Digital Trust-audits (27k): **€800/dag**
- Kilometers: **€0,40/km** · een "dag" = 8+ uur, halve dag = 4-8 uur
- Excl. btw; onkosten (eten/parking/tol) worden niet vergoed; audits buitenland bij voorkeur remote
- Annuleringsvergoeding: **£100 ex btw** (wederzijds)
- Factureren binnen **30 dagen** na afronding; BSI betaalt binnen **45 dagen**

---

1. Formulieren invullen en terugsturen

- [ ] **Supplier Data Collection Form** — bedrijfs- en bankgegevens (zie §4). Bankbewijs als PDF meesturen. Supplier Code of Conduct bevestigen.
- [ ] **GF077 Background Information & Declaration** — persoonlijke achtergrond + verklaringen + handtekening (zie §3 en §5).
- [ ] **Contractor Agreement (PSC)** tekenen — het hoofdcontract.
- [ ] **Netherlands Schedule** tekenen — NL-amendementen op het hoofdcontract (onder andere: je werkt volledig zelfstandig, geen dienstverband art. 7:610 BW, jij draagt eigen belasting/sociale premies).

---

2. Bedrijfsgegevens (Annex27 = Supplier)

Klaar / te bevestigen:

- [x] Bedrijfsnaam: **Annex27**
- [x] Ondernemingsnummer: **KBO/BCE 1006.203.170**
- [x] Adres: **Joseph Smeetslaan 1 bus 13630, 3630 Maasmechelen, België**
- [x] Rechtsvorm: **eenmanszaak** / **sole trader**
- [ ] Btw-nummer: **BE1006.203.170** — controleren of dit exact klopt op de VIES-registratie
- [ ] Contactgegevens: telefoon + e-mail die je op de forms zet (privé of info@annex27.nl?)
- [ ] Payment remittance e-mailadres (waar betaaladvies naartoe moet)

---

3. Persoonlijk + kwalificaties (Raoul = Contractor)

Achtergrondvragen GF077 sectie B (5 jaar terugkijkend):

- [ ] Ben je bestuurder/aandeelhouder in enige onderneming? → Ja (Annex27). Details invullen.
- [ ] Strafrechtelijke zaken / rechtszaken / schikkingen / toezichtszaken laatste 5 jaar die BSI kunnen schaden? → normaal: Nee.
- [ ] Ooit gediskwalificeerd/gesanctioneerd/gewaarschuwd door een accreditatie-instantie, ledenorganisatie of scheme owner? → normaal: Nee.
- [ ] Landen waar je hebt gewerkt én nog werkrecht hebt: **België, Nederland** (EU-werkrecht).
- [ ] Werkvisum: **n.v.t.** (EU-onderdaan).

Te bewijzen (sectie D, verificatie door BSI hiring manager):

- [ ] **Kwalificatie/opleidingscertificaten** — je ISO 27001 Lead Auditor-certificaat (en QHSE-relevante certs voor 9001/14001/45001/50001 waar van toepassing).
- [ ] **Lidmaatschap in good standing** — IRCA (Digital Trust / 27001) en/of **APSCA** waar vereist. Controleer of je registratie actueel is.
- [ ] **Werkervaring** — CV met relevante audit-ervaring. *Als "audit experience" niet aangetoond wordt, wordt de aanvraag afgewezen — dit is hard.*
- [ ] **2 referenties** — bedrijf + contactpersoon per referentie. Vraag ze nu alvast of ze willen dienen.

---

4. Financieel (bank, facturatie, verzekering)

Bankgegevens (Supplier Data Collection Form):

- [ ] Rekeninghouder-naam (moet Annex27 / Raoul Haas zijn zoals bij de bank bekend)
- [ ] **IBAN**
- [ ] **SWIFT/BIC**
- [ ] Banknaam, -adres, -land
- [ ] **Bankbewijs als PDF** — recent rekeningafschrift of bankbrief die de IBAN bevestigt. *Verstuur bankdata alleen via een kanaal dat BSI je aanwijst; zet nooit je IBAN + afschrift in een gewone onbeveiligde mail als BSI daar een portaal voor heeft.*

- [ ] Betaaltermijn 30 dagen akkoord? → **Ja**

Verzekering (Contract clausule 9 — verplicht) — IN BEHANDELING Plan: morgen bij **Jemar**, **AXA**, **BAV consultant €1M dekking**. Punten om af te vinken zodat de polis in één keer aan BSI voldoet:

- [ ] **BAV** (beroepsaansprakelijkheid) €1M — professional indemnity
- [ ] **BA uitbating** (bedrijfs-/uitbatingsaansprakelijkheid) — BSI eist deze náást BAV; dekt schade tijdens on-site audit
- [ ] Verzekerde = **Annex27, KBO 1006.203.170** (onderneming, niet privé)
- [ ] Activiteit omschreven als **"uitvoeren van ISO-conformiteitsaudits als onderaannemer"** (niet enkel "consultant")
- [ ] Geografische dekking minimaal **EU/EER**
- [ ] **Verzekeringsattest** meevragen om aan BSI te kunnen tonen (clausule 9)

Belasting/sociaal (NL Schedule + clausule 15):

- [ ] Jij (Annex27) draagt zelf btw, inkomstenbelasting en sociale bijdragen af. Geen dienstverband met BSI. → Stem af met je boekhouder hoe je BSI-omzet en de €750/€800-dagtarieven boekt (Belgische eenmanszaak, NL-klant, btw-verlegging B2B).

---

5. IT & encryptie (het technische deel dat je noemde)

Dit is waar het "start-klaar zijn" concreet wordt. BSI eist:

Laptop (clausule 4 + GF077-verklaring):

- [ ] Laptop met onderhouden OS + anti-virus + **volledige schijfversleuteling geïnstalleerd volgens BSI IT-richtlijn**.
- [ ] Je moet in GF077 verklaren: *"I confirm that I have encryption software loaded onto my laptop."*
- [ ] **Praktisch (Windows 11 Pro):** zet **BitLocker** aan op je systeemschijf (volledige-schijfversleuteling). Bewaar de herstelsleutel veilig (niet op dezelfde laptop). Controle-commando dat je zelf kunt draaien:

  ```
  manage-bde -status C:
  ```

  → moet "Protection On" / "Fully Encrypted" tonen. Zet 'm anders aan via Instellingen → Privacy en beveiliging → Apparaatversleuteling / BitLocker.
- [ ] Wacht op de **exacte BSI IT-richtlijn** (BSI IT Policies for Contractors). Zij kunnen een specifieke standaard of tool voorschrijven — volg die, ook als je al BitLocker hebt.

Data-omgang (GF077-verklaringen + clausule 12):

- [ ] **Alleen je BSI-e-mailadres** gebruiken voor álle BSI-gerelateerde communicatie (klanten, scheme owners, BSI-medewerkers). Niet je annex27- of privé-mail.
- [ ] **BSI-goedgekeurde e-mailfooter** gebruiken in alle BSI-communicatie.
- [ ] Alle klantinformatie (documenten, records, foto's, auditnotities, rapporten, deelnemersinfo, BSI-lesmateriaal) uploaden naar **Point Global** en **SFDC (Salesforce)**.
- [ ] Daarna **alle klantinformatie wissen van al je persoonlijke apparaten** (laptop, telefoon, camera,

USB-stick).

- [ ] Bij einde contract: **binnen 14 dagen** alle BSI-data onherstelbaar verwijderen, geen kopieën houden.

Data protection als verwerker (clausule 12 — technische + organisatorische maatregelen):

- [ ] Pseudonimisering + versleuteling van persoonsgegevens.
- [ ] Vertrouwelijkheid van iedereen met toegang.
- [ ] Herstelvermogen (back-up/restore) en periodieke test van je maatregelen.
- [ ] **Geen sub-verwerker** inschakelen zonder schriftelijke toestemming van BSI. *Let op: dit raakt Annex27's eigen stack. Cloud-diensten die BSI-data zouden verwerken (bv. je eigen Supabase/AI-pipeline) mag je hier niet zomaar voor gebruiken — houd BSI-auditwerk strikt binnen de BSI-systemen (Point Global/SFDC), gescheiden van het Annex27-platform.*
- [ ] Datalek: BSI **zonder onnodige vertraging** informeren; datasubject-verzoeken binnen **48 uur** melden aan BSI.

> **Eet je eigen hondenvoer:** je verkoopt ISO 27001 aan MKB. Richt je eigen laptop/werkwijze in zoals je klanten adviseert (schijfversleuteling, wachtwoordmanager, MFA, scheiding BSI-werk vs Annex27-platform, back-up + retentie). Dat is meteen je eigen bewijsvoering als auditor.

---

6. Doorlopende verplichtingen (na tekenen)

- [ ] **Belangenconflict** melden vóór elke opdracht (onafhankelijkheid t.o.v. de klant).
- [ ] **Vertrouwelijkheid** — geldt door tot 5 jaar na einde contract.
- [ ] **Non-solicitatie** — 12 maanden na einde geen BSI-klanten of BSI-sleutelpersonen benaderen/afwerven.
- [ ] **IP** — alle auditrapporten en materialen zijn eigendom van BSI/klant.
- [ ] **Kwalificaties actueel houden** (IRCA/APSCA in good standing, bijscholing).
- [ ] **Verzekering geldig houden** en op verzoek tonen.
- [ ] **Factureren binnen 30 dagen** na afronding, in het door BSI voorgeschreven systeem/format met SOW/PO-referentie en rapport.

Wat ik voor je kan doen

- De **twee formulieren (Supplier Data Collection + GF077) invullen** als concept met je bekende gegevens, zodat jij alleen hoeft te controleren/ondertekenen. *(Bank- en gevoelige velden laat ik leeg — die vul je zelf in en verstuur je via het door BSI aangewezen kanaal.)*
- Een **scheidingsopzet** schrijven: hoe je BSI-auditwerk technisch en organisatorisch gescheiden houdt van het Annex27-platform (voldoet aan clausule 12).
- Een **Annex27 ISMS-mini** voor jezelf als eenmanszaak (laptop-hardening, retentie, back-up, breach-procedure) die tegelijk je BSI-verklaringen onderbouwt.
- Een **verzekering-briefing** opstellen die je naar een makelaar kunt sturen (dekking passend bij zelfstandig ISO-auditor).

Wat alleen jij kunt / professioneel advies

- Contracten **ondertekenen**.
- **Bankgegevens + afschrift** aanleveren (nooit door mij te doen).
- **Verzekering** afsluiten (via makelaar).
- **Belastingstructuur** BSI-omzet afstemmen met je **boekhouder** (BE-eenmanszaak, NL-opdrachtgever, btw-verlegging).
- **BitLocker/encryptie aanzetten** op je laptop (systeeminstelling — jij voert uit, ik begeleid).
